PROJECT DOCUMENT

Alice

A self-hosted platform for managing an organisation's TLS certificates, Azure Key Vault certificates and SSH keys

This document explains what Alice is, the problem it solves, how it is built, how it keeps secrets safe, and where the project stands today. It is written for three readers at once: a cyber security specialist, a colleague who is new to networking, and the manager of the software team. A short reading guide on the next page shows each of them where to start.

Version	Development build, `main` at commit 39f724f9
Date	19 October 2026
Sources	The product guides in `docs/`, `CHANGELOG.md`, the source code, and the running application. The screenshots come from the English interface of a test installation with sample data.
Status	Feature-complete for version 1; owner verification steps outstanding (section 14)

How to read this document

Each section is tagged with the reader it matters most to. Every section is written so that anyone can follow it, and technical terms are explained when they first appear. Section 2 is a short introduction to the networking and security ideas that the rest of the document relies on.

Manager

Software team manager

Start with the **executive summary (1)**, then **project status and risks (14)** and **engineering practice (13)**. Sections 3 and 4 show what the product does and how it fits together.

Security

Cyber security specialist

Read **architecture and trust boundaries (4)**, **identity and access (8)** and **security architecture (9)**, which includes the threat model. Sections 6, 7 and 10 cover the risky operations: deployment, key rotation and backups.

Network beginner

New to networking

Read the **primer (2)** first. Then read **what Alice does (3)**, the **architecture diagram (4.1)** and the **interface tour (5)**. The **glossary (Appendix A)** explains the terms.

Contents

1	Executive summary	Manager
2	Primer: certificates, keys and the network	Beginn
3	What Alice does	All
4	Architecture, data flow and trust boundaries	Security Beginn
5	Installation, first run and a tour of the interface	Beginn
6	Certificate management and deployment	Security
7	SSH keys, Azure Key Vault, ACME and network discovery	Security
8	Identity, roles and access	Security
9	Security architecture and threat model	Security
10	Backup, restore and upgrade	Security Manager
11	Licensing and the vendor console	Manager
12	The API and day-to-day operation	Security
13	Engineering practice: stack, testing and CI	Manager
14	Project status, limitations and open items	Manager
A	Glossary · **B**Network ports · **C**Error code families	

1 Executive summary

Alice is a management platform that an organisation runs on its own server. It finds, deploys, renews and audits the organisation's TLS certificates, Azure Key Vault certificates and SSH keys from one place. It runs on a single Linux server as two Docker containers: the application and a PostgreSQL database. It needs no internet connection, never contacts the vendor and sends no telemetry.

> **Why it matters**
>
> An expired certificate takes a website or service offline. An SSH key that nobody remembers is a back door and becomes an audit finding. In many organisations both are tracked by hand in spreadsheets. Cloud tools solve this, but they require private keys and server access to leave the organisation, and regulated sectors (in Turkey, organisations under KVKK and BDDK rules) often cannot accept that. Alice keeps everything inside the organisation.

v1	8 / 8	143	0
Feature-complete: phases 0–11, plus network discovery, LDAP/AD sign-in, Apache and HAProxy discovery	CI jobs green on the latest commit (unit, integration, coverage, real-server matrix, secrets, end-to-end stack)	End-to-end browser journeys passing in the latest full run	Bytes sent to the vendor; no telemetry, no update check

At a glance

What it does	Finds certificates and SSH keys on Nginx, Apache, HAProxy and Linux servers. Deploys certificates to Nginx and rolls back automatically if something fails. Generates and rotates SSH keys. Watches Azure Key Vault. Obtains and renews certificates through ACME (for example Let's Encrypt). Scans the network for certificates nobody manages.
Who it is for	IT infrastructure teams, system operators, and security and audit teams. Three roles: Administrator, Operator, Auditor.
Where it runs	One Linux x86_64 server (Ubuntu 22.04+, Debian 12+, RHEL/Rocky/Alma 9+) with Docker Engine 24+.
Security baseline	Multi-factor authentication for every local account, encryption of every stored secret (AES-256-GCM), a tamper-evident audit trail, encrypted backups, signed release bundles, hardened containers.
Languages	English and Turkish; each user picks their own.
Licence model	Per installation, priced by the number of managed targets (servers and Key Vaults). 30-day evaluation. Licences are offline files signed with a hardware key (YubiKey).

Where the project stands

The code is complete for version 1, and the full CI pipeline is green. What remains before the first customer release is mostly work **only the project owner can do**: a test against a real Active Directory, the offline release-key ceremony, signed test installs on Rocky Linux with SELinux, an external penetration test, and a first disaster-recovery drill. Section 14 has the full list and the known risks.

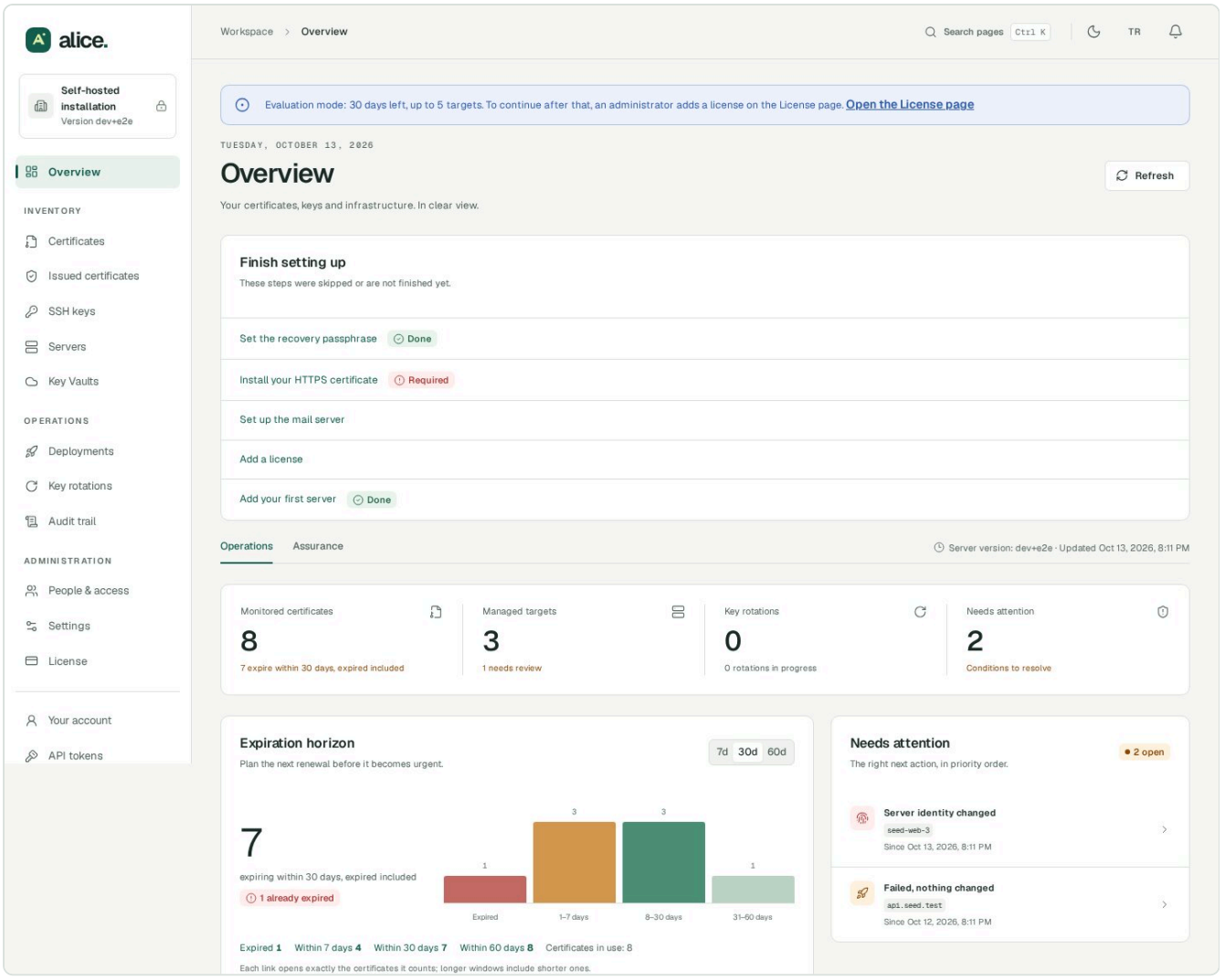


Figure 1. The Overview page after sign-in. Navigation on the left is grouped into Inventory, Operations and Administration. Every number is a link to the exact list it counts.

2 Primer: certificates, keys and the network

This section is for readers who are new to networking and security. It explains, in plain terms, the handful of ideas Alice is built around. Readers who already know them can skip to section 3.

2.1 Servers, ports and protocols

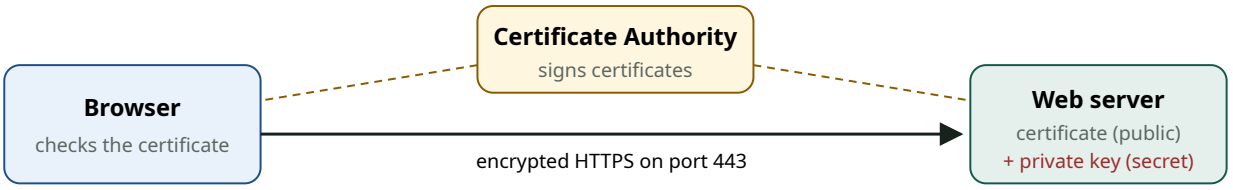
A **server** is a computer that offers a service to others over the network, for example a website. Every computer on a network has an **IP address** (such as `10.0.4.17`), and people usually reach it by a **DNS name** (such as `shop.example.com`). DNS is the network's phone book: it turns names into addresses.

One server can offer many services, so each service listens on a numbered **port**. By convention HTTPS websites use port **443**, SSH uses port **22**, and plain HTTP uses port **80**. A **firewall** decides which ports may be reached from where. When this document says "Alice connects out on TCP 22", it means Alice opens SSH connections to other servers' port 22.

2.2 TLS certificates: the website's ID card

When you open `https://shop.example.com`, the connection is protected by **TLS** (the "S" in HTTPS). TLS does two things: it **encrypts** the traffic so nobody in between can read it, and it **proves the server's identity** so you know you are not talking to an impostor.

The proof is a **certificate**, a small file that says "this public key belongs to shop.example.com" and is signed by a **Certificate Authority (CA)** that browsers trust. Each certificate is paired with a **private key** that stays secret on the server. Anyone with the private key can impersonate the site, so the key must be protected.



The browser trusts the CA, the CA vouches for the server, so the browser trusts the server.

Certificates **expire**, typically after 90 days to a year. If nobody renews and installs a new one in time, browsers refuse to connect and the service is effectively down. Certificates often come with a **chain** of intermediate CA certificates. A server that sends an incomplete chain works in some clients and fails in others.

Web servers such as **Nginx**, **Apache httpd** and **HAProxy** (a load balancer) are the programs that actually present certificates to users. Each of them has configuration files that name which certificate and key file to use.

2.3 ACME: automatic certificates

ACME is a standard protocol (RFC 8555) that lets software request a certificate from a CA automatically. Let's Encrypt is the best-known ACME CA. To get a certificate for a name, you must prove you control it, either by publishing a temporary DNS record (**DNS-01**) or by serving a temporary file on the website (**HTTP-01**).

2.4 SSH keys: the administrator's key ring

SSH is how administrators (and programs such as Alice) log in to Linux servers remotely. Instead of a password, SSH usually uses a **key pair**: the private key stays with the person, and the public key is added to a file called `authorized_keys` on each server they may enter. Over the years these files fill up with keys of people who left, of old scripts, and keys nobody can explain. Each one is a door that still opens. **Key rotation** means replacing a key with a new one on a schedule, so that a leaked old key stops working.

2.5 Key vaults, directories and single sign-on

- **Azure Key Vault** is Microsoft's cloud safe for certificates, keys and secrets. Many organisations keep their master copy of a certificate there and need it copied to their web servers whenever it changes.
- A **directory** (Active Directory, OpenLDAP) is the organisation's central list of people, passwords and groups. **LDAP** is the protocol used to query it; **ldaps** is LDAP over TLS.
- **Single sign-on (SSO)** with **OpenID Connect (OIDC)** lets people sign in through their organisation's identity provider (Microsoft Entra ID, AD FS, Keycloak) instead of a separate password.
- **MFA** (multi-factor authentication) means a password plus a second proof, usually a 6-digit code from a phone app (**TOTP**).

> **In one sentence**
>
> Alice keeps a live inventory of every certificate and SSH key on the organisation's servers, warns before anything expires, and can safely replace certificates and keys on its own, without the secrets ever leaving the organisation.

3 What Alice does

3.1 The solution in short

Alice keeps the inventory on the organisation's own server and manages it from there. It connects to managed servers with its own SSH key. On each server, a small helper program (`alice-helper`) does the privileged file work under a narrow `sudo` rule that allows only a fixed set of commands. No data flows to the vendor.

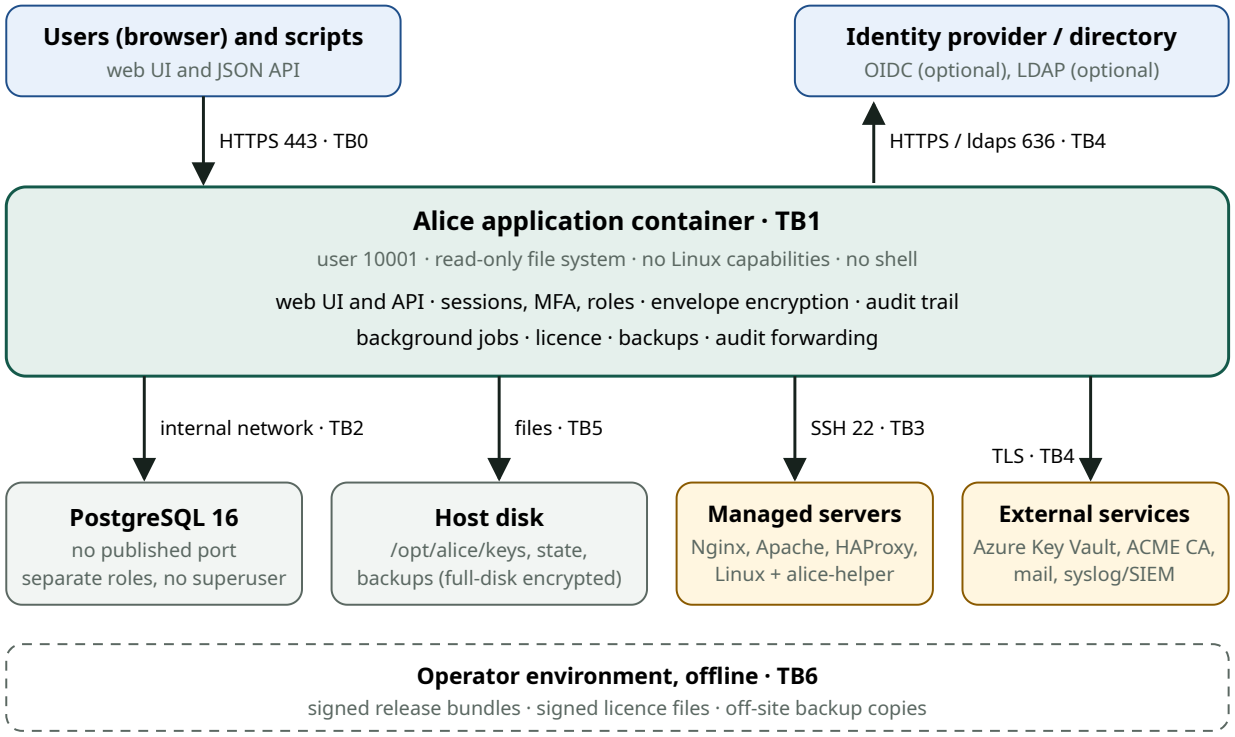
3.2 Feature overview

Area	What Alice provides
Certificate inventory	Certificates found on servers, uploaded certificates (PEM/PFX) and signing requests (CSR, where the private key never leaves Alice). Chain-integrity checks, expiry filters, saved views and CSV export.
Certificate deployment	Step-by-step deployment to Nginx websites: check the current certificate, back up, write, `nginx -t` , reload, verify. Automatic rollback on failure. An interrupted deployment's outcome is followed up automatically.
Supported web servers	**Nginx** discovery and deployment. **Apache httpd** **HAProxy** discovery only: Alice reads their configuration and certificates and warns before expiry, but does not yet deploy to them. Their deploy buttons appear disabled with "Not available for ... servers yet". **Linux** servers for SSH keys.
SSH keys	Discovery of every authorised key on every server. Findings such as weak keys, duplicates, or root keys with no source-address limit. Key removal from one place. Generation, deployment, download and automatic rotation of Alice-made keys, with an overlap period and log-in checks.
Azure Key Vault	Monitoring of vaults (certificates, keys, secret metadata). Automatic or manual deployment of new versions to Nginx websites. Importing certificates into a vault.
Certificate authorities (ACME)	Certificates from Let's Encrypt or an internal CA through a DNS hook or HTTP-01. Automatic renewal and deployment. A "Test run" that proves the setup without issuing anything.
Network discovery	Finds certificates that servers present on the network, including ones Alice does not manage, by opening a TLS handshake within administrator-defined scopes only. Strict protections stop it from being abused to reach internal services (SSRF).
Identity and access	Mandatory TOTP MFA and recovery codes, three roles, re-authentication for sensitive actions, SSO through OpenID Connect, sign-in with LDAP or Active Directory, and personal API tokens with limited scopes.
Audit and compliance	A hash-chained, append-only audit trail with a daily integrity check, CSV/JSON export, forwarding to syslog/SIEM (RFC 5424), and a KVKK/BDDK control mapping.
Continuity	Daily encrypted backups, restore to the same or a new server, a disaster-recovery drill, and signed upgrade bundles with automatic fallback.
Notifications	E-mail for certificate expiry, failed deployments, failed backups, licence warnings, sign-in blocks and rotations. Recipients and thresholds can be configured.

4 Architecture, data flow and trust boundaries

4.1 Components and data flow

Alice runs on one Linux server as two containers started by Docker Compose: the **application container** (web interface, API and background jobs) and the **PostgreSQL database**. A third, short-lived container is started from the same image only for maintenance commands such as backup, restore and database migration. The labels **TB0–TB6** mark the trust boundaries described in 4.2.



- People use the web interface over HTTPS. Scripts use the same JSON API with personal API tokens.
- Alice connects **outwards** to managed servers with its own SSH key. On each server, `alice-helper` does the privileged work through a fixed command set under a narrow sudoers rule.
- Azure, the ACME CA, the DNS hook, the mail server, syslog and the directory are contacted **only** after an administrator configures them, and only over verified TLS.
- Nothing goes to the vendor. There is no telemetry and no update check.

4.2 Trust boundaries Security

Boundary	Between	Protection
TB0	Browser and Alice	HTTPS (TLS 1.2+), HSTS, strict CSP, a SameSite=Strict session cookie, a CSRF token and same-origin check, and sign-in rate limits.
TB1	Alice process and its database and key volume	The application uses a database role that can only insert and read the audit trail; triggers refuse changes to it. The master key is a file readable only by the container user.
TB2	Database	Reachable only on the internal Docker network, with no published port. SCRAM-SHA-256, separate roles for the application and the schema owner, no superuser.

Boundary	Between	Protection
TB3	Alice and managed servers	An SSH host key pinned at first contact and approved by an administrator. Everything a server returns is treated as untrusted. A fixed-command helper. An address rule on every connection (link-local and cloud metadata addresses are refused).
TB4	Alice and cloud or corporate services	TLS verified against the system CAs (and the corporate CA, if one is set), plus the same address rule.
TB5	Containers and host	Non-root containers, a read-only root file system, all capabilities dropped, `no-new-privileges`.
TB6	Offline environment	Ed25519-signed release bundles, vendor-signed licence files, encrypted backups whose origin is verified.

4.3 The server-side helper and the provider model

Alice never runs arbitrary commands on a managed server. The helper is a small static program owned by root. Through `sudo` it exposes a fixed list of subcommands such as `sshd-dump`, `authkeys-list`, `nginx-dump`, `apache-dump`, `haproxy-dump` and the deployment journal. Its checksums are built into Alice, and the preparation script refuses a helper with the wrong checksum. The current helper is **1.8.0, protocol 9**.

Each type of server is a **provider** with declared **capabilities**, for example "can deploy" or "can serve an ACME HTTP-01 token". The interface turns features on and off from these capabilities instead of from hard-coded server types. That is why Apache and HAProxy servers look like Nginx servers, but with the deploy controls disabled.

The helper runs a web server binary (`nginx`, `apachectl`, `httpd`, `haproxy`) as root only when the program and every directory above it belong to root and cannot be written by group or others. Otherwise it reports the configuration as untrusted.

5 Installation, first run and a tour of the interface

5.1 Server requirements

Item	Minimum	Recommended (hundreds of servers, thousands of certificates)
Operating system	Linux x86_64: Ubuntu 22.04+, Debian 12+, RHEL/Rocky/Alma 9+	same
Docker	Docker Engine 24+ and the compose plugin (v2)	Docker Engine 26+
CPU / memory	2 vCPU / 4 GB (warning at 3 GB; refused below that)	4 vCPU / 8 GB
Disk	20 GB free on the `/opt/alice` partition, **full-disk encryption required**	50 GB
Inbound network	TCP 443 (or a chosen port) from users' workstations	same
Outbound network	TCP 22 to managed servers; as needed, TCP 443 to Azure, mail, identity provider, syslog, and ldaps 636	same
Time	NTP-synchronised clock (licence and certificate dates depend on it)	same

> **Network note for beginners**
> Docker writes its own packet-filter rules, so `ufw` rules do not see the ports Docker publishes. Put a network firewall in front of the server, or use the `DOCKER-USER` chain, and open only the HTTPS port.

5.2 Verify, then install

The vendor delivers a bundle, its checksum, a signature of the checksum and the public release key. The key's fingerprint is published through a **separate channel** (website or licence e-mail), so a tampered download cannot also fake the fingerprint.

```
# 1. Is this the key the vendor published?
openssl pkey -pubin -in rk-2026-01.pem -outform DER | sha256sum
# 2. Was the checksum file signed with this key?   ("Signature Verified Successfully")
openssl pkeyutl -verify -pubin -inkey rk-2026-01.pem -rawin -in alice-1.0.0.tar.gz.sha256 -sigfile
alice-1.0.0.tar.gz.sha256.sig
# 3. Does the bundle match the checksum?            ("alice-1.0.0.tar.gz: OK")
sha256sum -c alice-1.0.0.tar.gz.sha256

# Install
sudo mkdir -p /root/alice-1.0.0
sudo tar --no-same-owner -xzf alice-1.0.0.tar.gz -C /root/alice-1.0.0
sudo /root/alice-1.0.0/alice/install.sh --hostname alice.example.com
```

The installer first runs pre-checks that change nothing. It then copies the bundle into a root-only directory and verifies that copy, shows the release-key fingerprint and waits for `yes`, creates `/opt/alice`, generates three random database passwords and the master key, loads the two images from the bundle (never from a registry), starts the database and Alice, and finally prints the address and a **one-time setup code**, only to the terminal.

5.3 First run: the setup wizard

Opening `https://<address>/setup` starts a 12-step wizard (about 15 minutes) grouped under seven headings: setup code and language, the first administrator and MFA, recovery codes, the backup recovery passphrase, the HTTPS certificate, the mail server, the licence and the first server. If the browser is closed part-way, the next sign-in resumes at the first unfinished step.

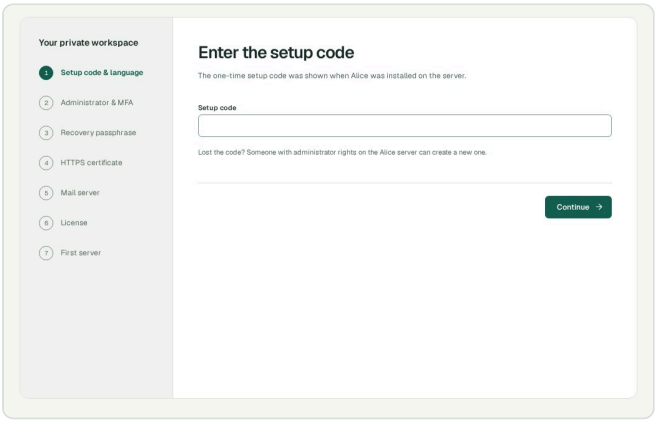


Figure 2. Step 1: the one-time setup code. After five wrong codes from one computer the wizard waits 15 minutes.

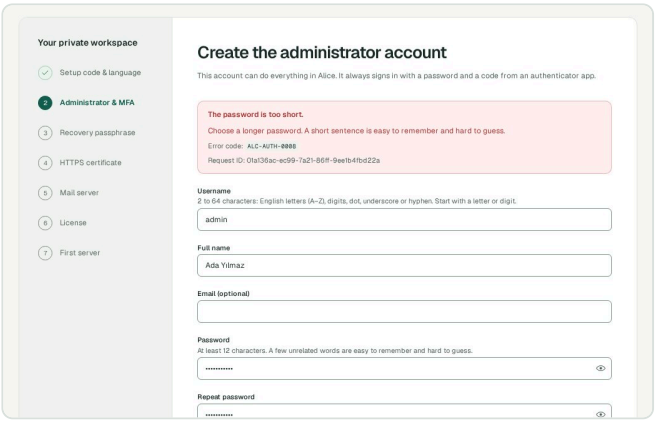


Figure 3. A password shorter than 12 characters, or one found in a list of 100,000 leaked passwords, is refused with an explanation.

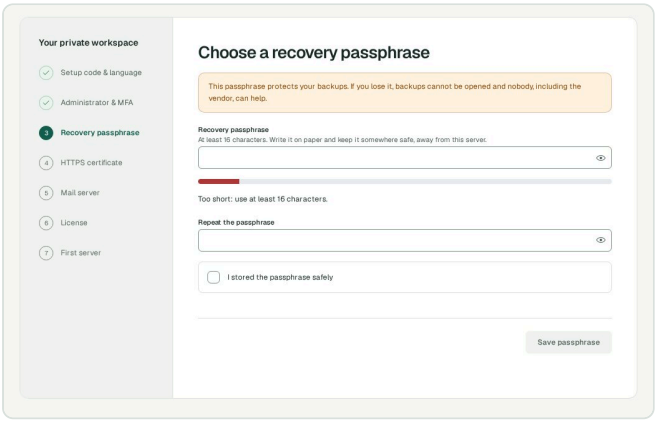


Figure 4. The recovery passphrase protects every backup. It cannot be changed in this version. If it is lost, nobody (the vendor included) can open the backups.

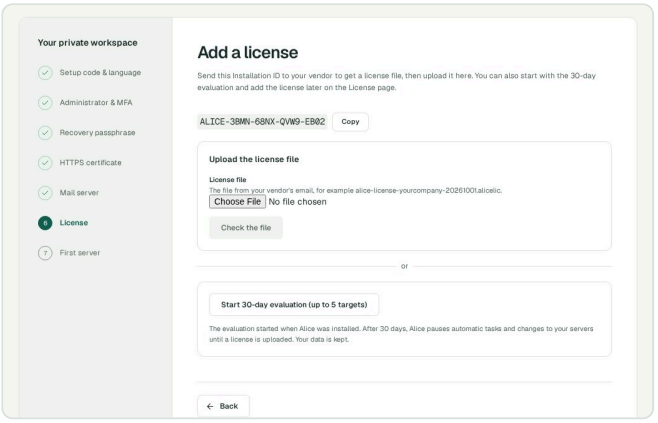


Figure 5. The Installation ID is shown. A licence file can be uploaded, or a 30-day evaluation for up to 5 targets can be started.

5.4 A tour of the interface

The left navigation has three groups. **Inventory**: Certificates, Issued certificates, Network discovery, SSH keys, Servers, Key Vaults. **Operations**: Deployments, Key rotations, Audit trail. **Administration**: People & access, Settings, Licence. The top bar has page search (Ctrl K), theme and language switches and the notification bell. Every page also works at phone width.

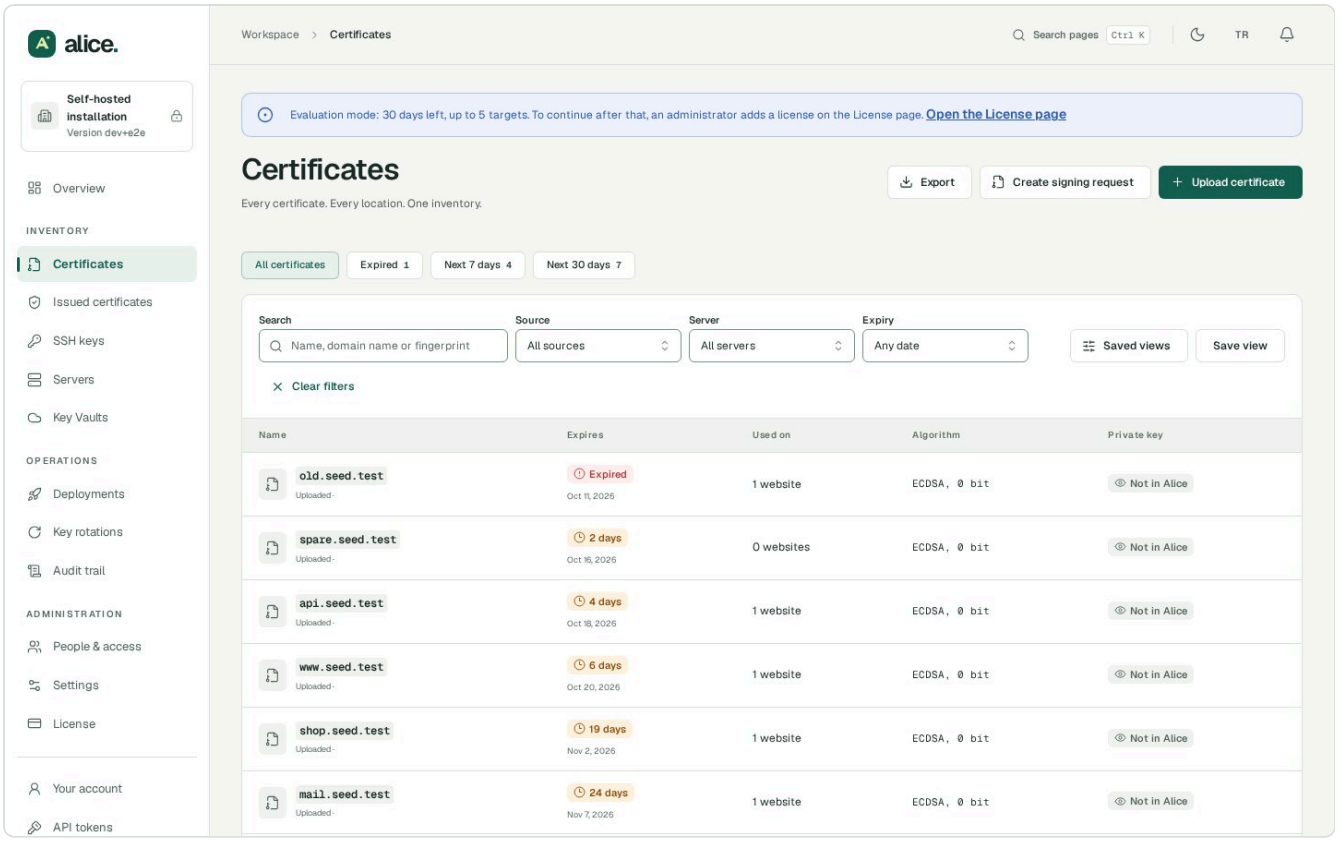


Figure 6. Certificates: one inventory showing name, expiry, where each certificate is used, algorithm, and whether Alice holds the private key. Quick filters (expired, 7 days, 30 days), saved views and export.

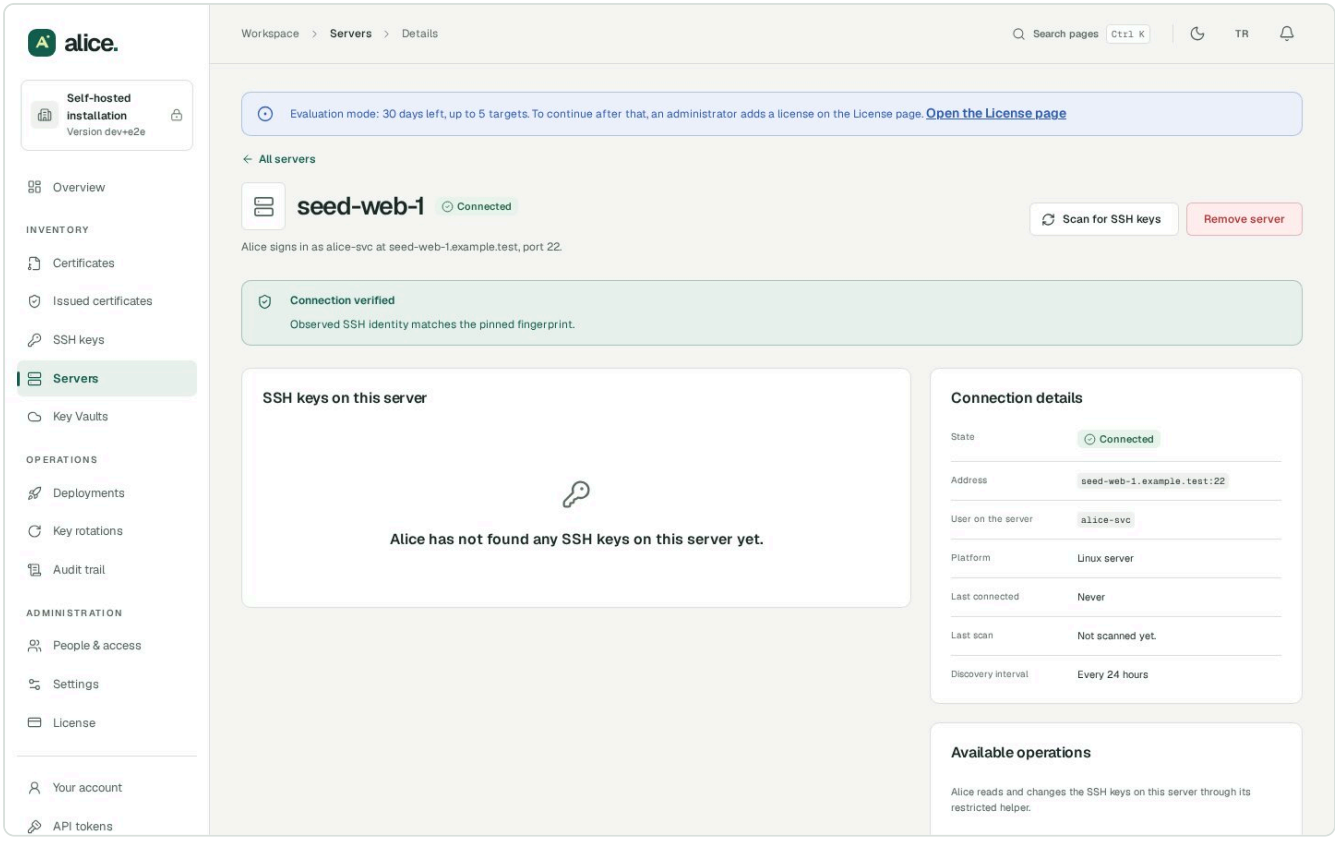


Figure 7. Server detail: connection check (the pinned SSH fingerprint), the SSH keys on this server, and actions (test connection, scan SSH keys, remove server).

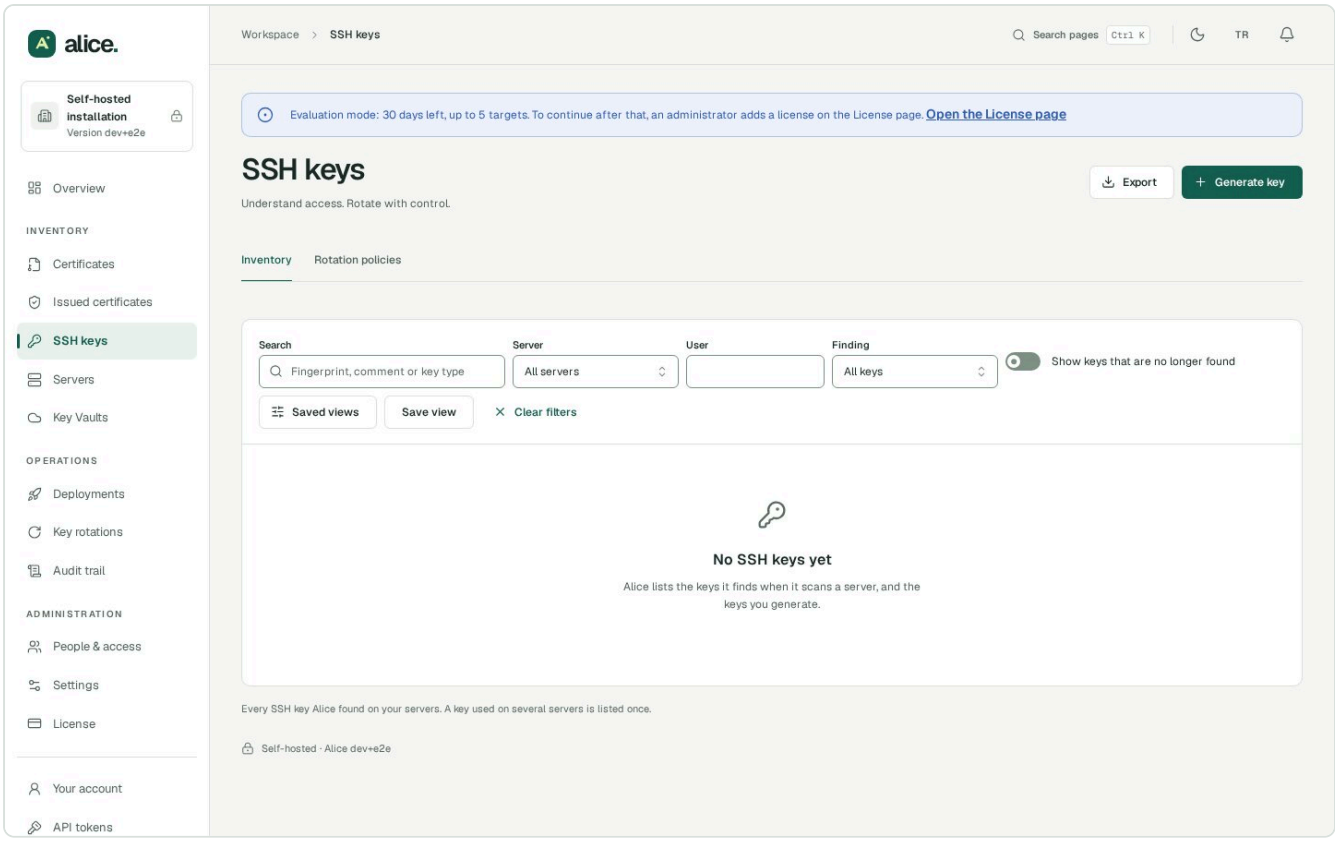


Figure 8. SSH keys: every authorised key collected from the servers, listed once, with finding filters (weak key, forced command, unrestricted root key, duplicate, CA, hardware key).

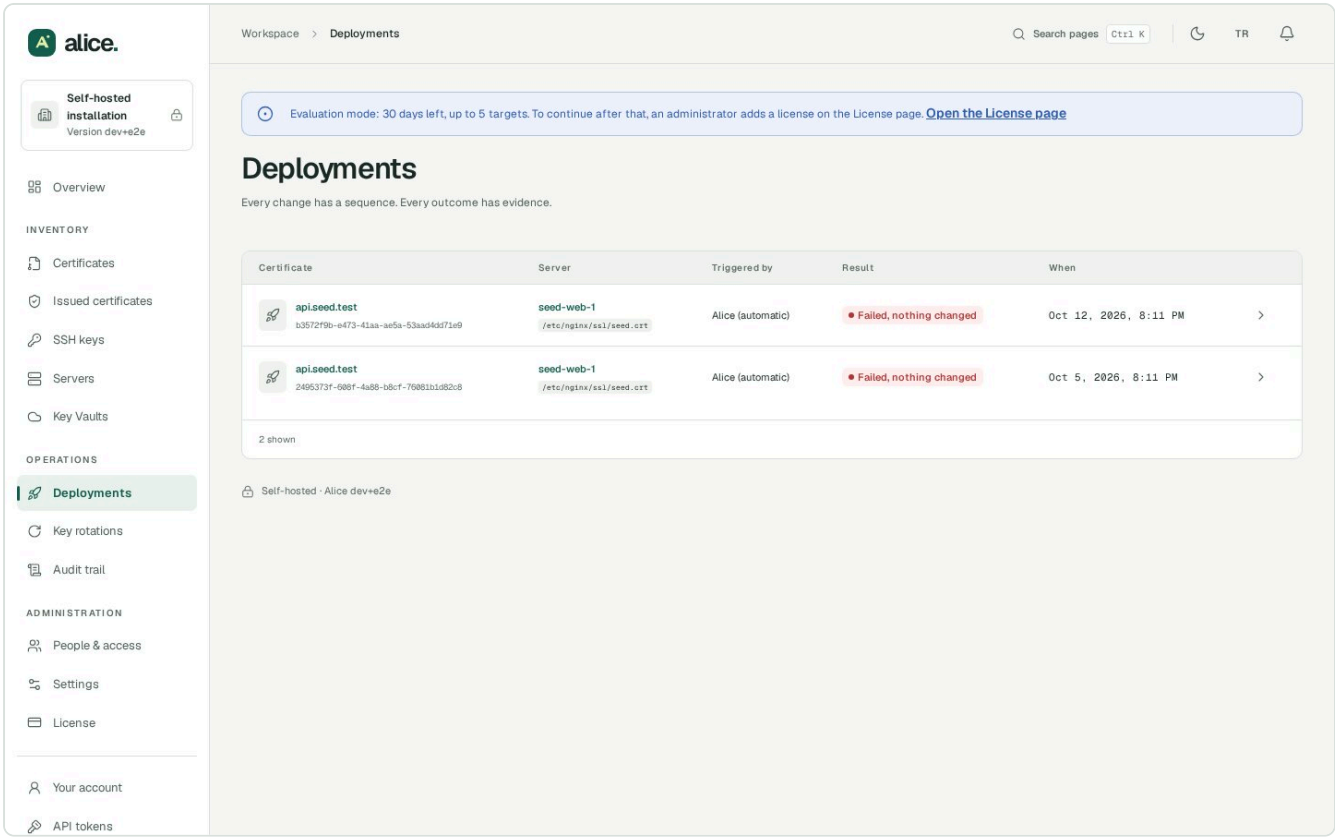


Figure 9. Deployments: every deployment, newest first, with certificate, server and file, who triggered it (a person or Alice), outcome and time.

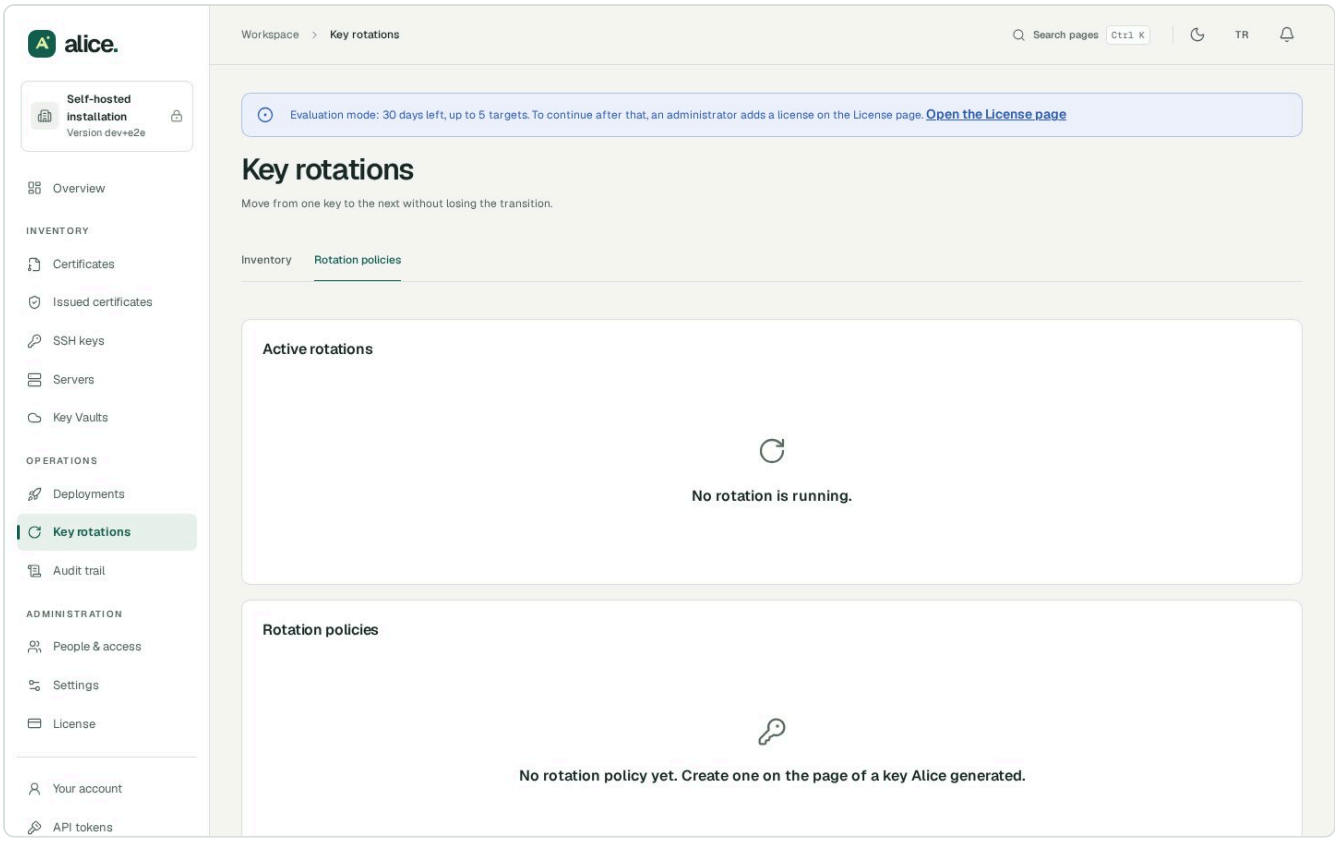


Figure 10. Key rotations: progress of running rotations (generate, deploy and verify, overlap, retire the old key) and the rotation policies.

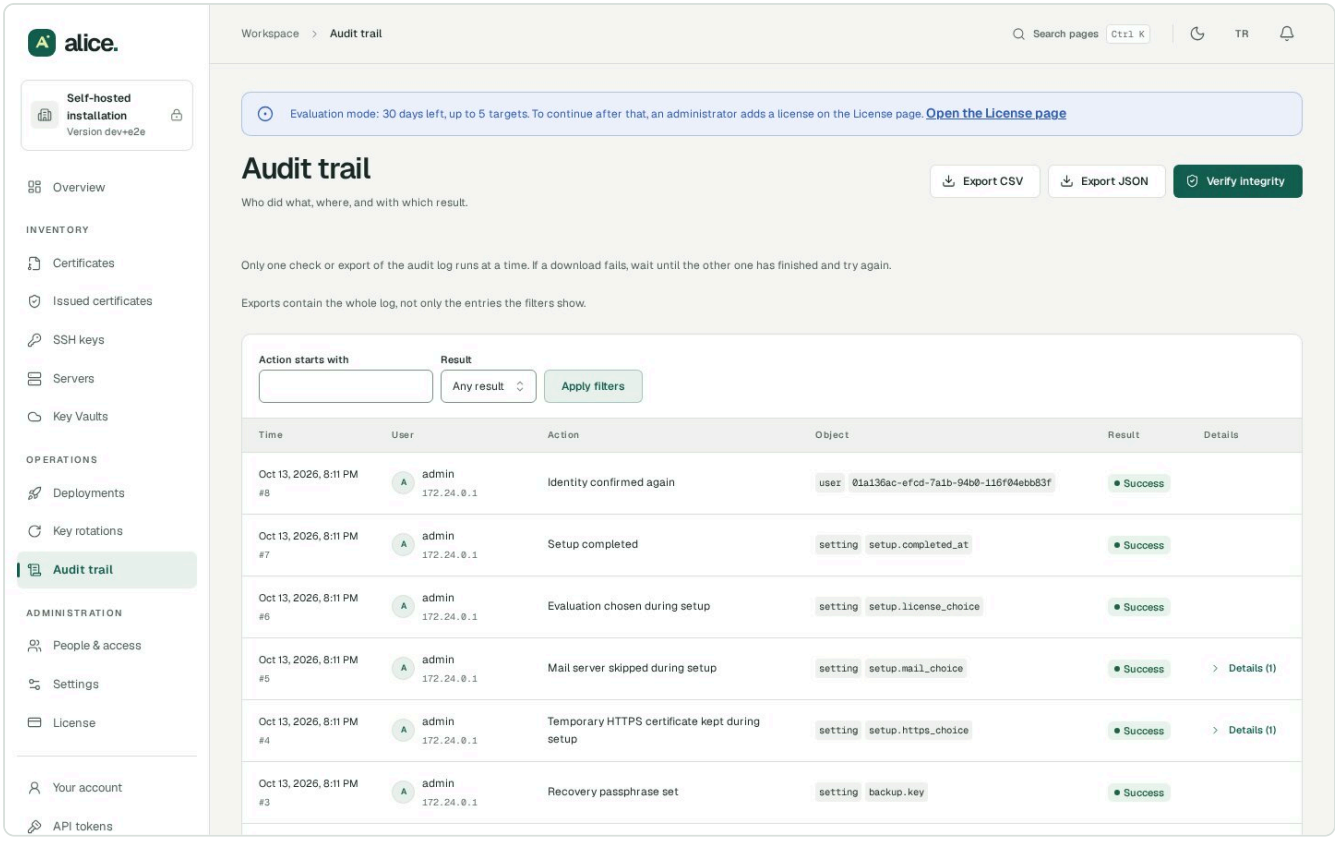


Figure 11. Audit trail: who did what, from where, and with what result. CSV/JSON export and "Verify integrity".

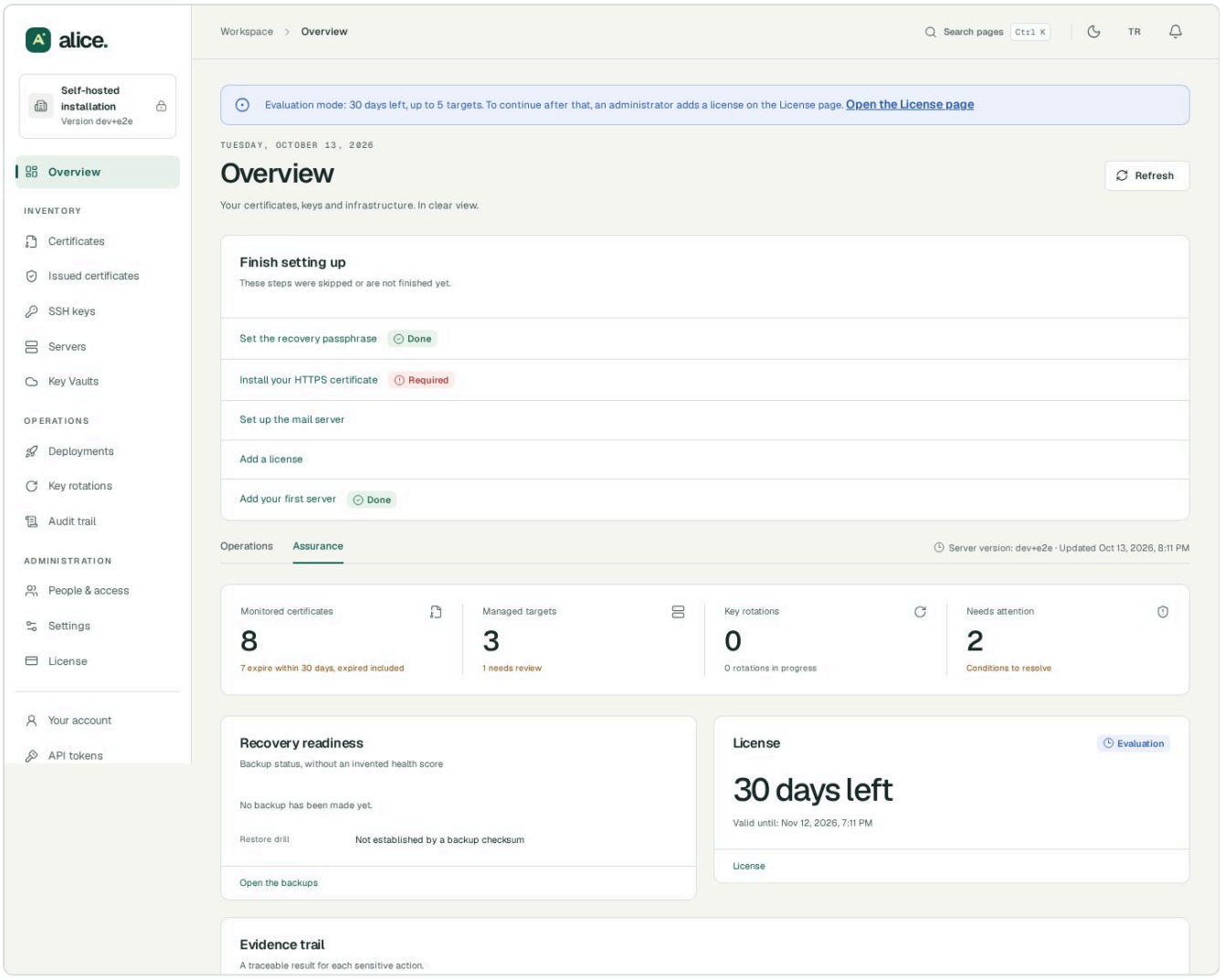


Figure 12. The Assurance tab of the Overview, for administrators and auditors: audit-chain integrity, recovery readiness (age of the last good backup, restore drill), licence status and the latest audit entries.

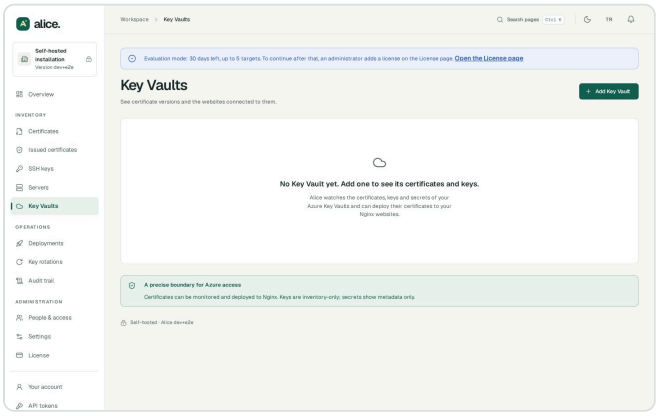


Figure 13. Key Vaults: each vault is a licence target, shown with status, sign-in method and last successful check.

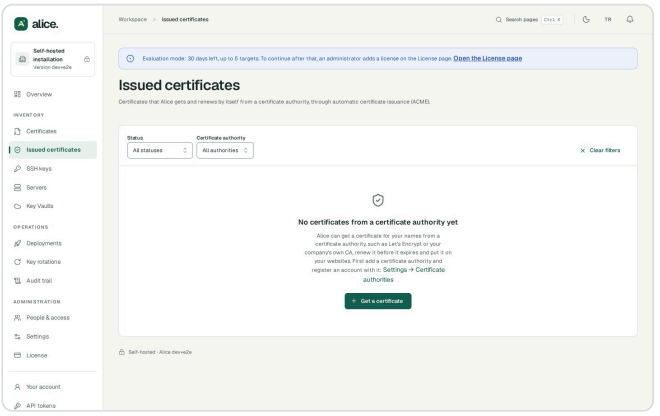


Figure 14. Issued certificates (ACME): names, authority, status, proof method, expiry, next renewal, and the auto-renew and auto-deploy switches.

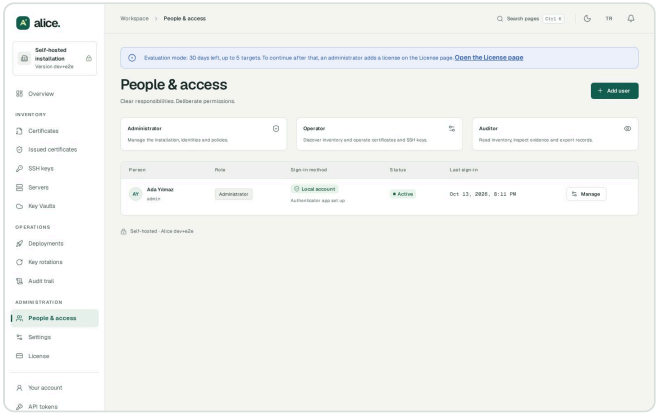


Figure 15. People & access: users, roles and sign-in method (local, SSO, directory).

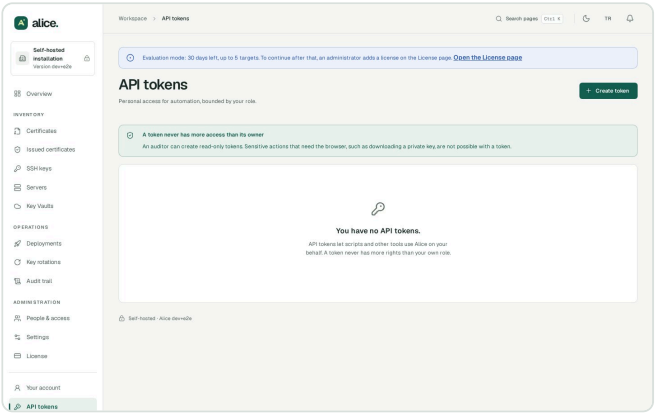


Figure 16. API tokens: personal, scoped (read / read and operate), valid for at most 365 days, and shown only once.

The screenshots were taken from the 13 October 2026 build with sample data. The network-discovery, directory and Apache/HAProxy pages added since then follow the same layout.

6 Certificate management and deployment

6.1 Adding a server

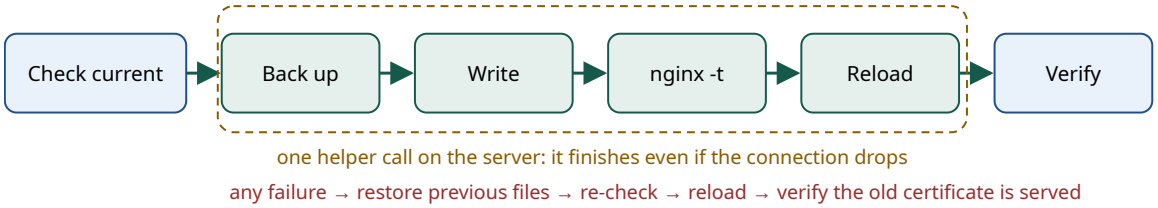
A server is added as a Linux, Nginx, Apache or HAProxy server; the type cannot be changed later. On the server, an administrator runs the preparation commands that Alice shows. They create the account `alice-svc`, add Alice's public key with forwarding and PTY disabled, install the checksum-verified helper, and install a sudoers file that allows only the helper subcommands of that server type.

At the first connection Alice records the server's SSH fingerprint and asks an administrator to approve it (**trust on first use**). If the fingerprint changes later, Alice stops all work on that server and marks it **Server identity changed**, because a changed fingerprint can mean someone is intercepting the connection. Alice re-scans every connected server once a day.

6.2 Where certificates come from

- **Found on servers:** every certificate file named in the Nginx, Apache or HAProxy configuration. Private keys are **never** read from a server; such certificates show "not in Alice".
- **Uploaded:** PEM text or a PFX file. The key must match a certificate in the upload, the certificate must not be expired, the key must be RSA 2048–16384 or ECDSA P-256/P-384, and the chain must contain no MD5 or SHA-1 signatures. A certificate with an incomplete chain is stored with a warning and can be deployed only with an administrator's approval.
- **From a signing request (CSR):** Alice generates the key and the CSR, so the private key never leaves Alice. The signed certificate is added later.
- **Issued through ACME:** see 7.3.

6.3 How a deployment works (Nginx)



Step	What it means
Check current certificate	Alice connects to the website and confirms it still serves the certificate Alice last saw. If not, it stops without changing anything.
Back up	The helper copies the current certificate and key to `/var/lib/alice-helper/backups/<deployment id>`.
Write	Key and certificate files are replaced atomically.
Check · Reload	`nginx -t`, then `systemctl reload nginx` (never restart, so open connections are kept).
Verify	Every HTTPS port of the website must serve the new certificate with the expected chain. This is checked from Alice's network or, if that cannot reach it, from the server itself.

If Alice gets no clear answer, it **never re-sends** the deployment. It moves to "Confirming result", asks the helper for the outcome about 30 seconds later and, if the helper has no record, tells it to refuse that deployment

permanently (a **fence**) before closing it as failed. This prevents a delayed duplicate from overwriting a newer certificate.

Outcome	Meaning	What to do
Succeeded	The new certificate is live and verified.	—
No change needed	The website already used this certificate.	—
Failed, nothing changed	Alice stopped before writing.	Fix the cause and deploy again.
Failed, restored	Files were written but a check failed; the previous certificate was put back.	Read the `ALC-DEP-…` code and deploy again.
Result not verified	The previous files could not be restored or verified.	Check the site at once; see the backup on the server.
Attention needed	Alice is still trying to learn the result (server unreachable).	Check the connection to the server.

> Apache and HAProxy servers are **discovery only** in this version. Alice reads their configuration (Apache include trees and `IfModule` / `IfDefine` blocks; HAProxy `bind` lines, `crt-list` files and `crt` folders) and warns about expiry, but never writes to them or reloads them.

7 SSH keys, Azure Key Vault, ACME and network discovery

7.1 SSH keys and rotation

Alice reads the `authorized_keys` files of every account on managed servers and lists each public key once, with server, user, file, line, options (`command=` , `from=`) and last seen. Keys that disappear are marked "No longer found" and are never deleted from the records.

Remove key deletes only that key's lines from that file. Alice protects its own connection key and root's last key (unless an administrator explicitly confirms). It also refuses to change servers that fetch keys through `AuthorizedKeysCommand` or whose SSH settings it cannot read, and every such refusal is audited.

Alice-generated keys (Ed25519 recommended; RSA 3072/4096; ECDSA P-256) are stored only encrypted. A **rotation** adds the new key next to the old one wherever it is used, confirms that log-in works with the new key, keeps both for the overlap period (default 7 days), checks again, and only then removes the old key. A policy is created switched off; an administrator turns it on with a fresh MFA code. "Preview next run" shows exactly what would happen without changing anything. Where a log-in cannot be confirmed, the run stops and waits for an administrator.

7.2 Azure Key Vault

An Azure administrator registers an application for Alice (certificate authentication recommended; a client secret or a managed identity also work) and grants it roles on the vault. Alice checks each vault every 15 minutes by default (5–1440), backs off on failure, and shows certificates, keys and **only the metadata** of secrets: it never reads or shows a secret's value. Nginx websites can be linked to a vault certificate, and with auto-deploy on, new versions are deployed automatically. A version that appears during a licence lock is **held** for an administrator instead of being deployed.

7.3 Certificate authorities (ACME)

Alice can obtain certificates from any ACME CA (Let's Encrypt, ZeroSSL, or internal CAs such as step-ca or EJBCA), renew them before they expire and, if asked, deploy them. Nothing is contacted until someone acts: adding an authority or DNS hook only saves settings.

- **Setup (administrator):** the authority's directory URL (https only) and allowed domain suffixes; an account (e-mail, terms, optional EAB); a proof method, either a DNS hook (the organisation's HTTPS endpoint that writes the `_acme-challenge` record; required for wildcards) or HTTP-01 on a managed Nginx server.
- **Test run** proves every name can be validated without issuing a certificate.
- **Renewal** happens automatically when the remaining lifetime falls below the chosen number of days or a third of the lifetime. On failure Alice retries after 1, 2, 4, 8 and 16 hours, then daily; it sends e-mail on the third failure and stops at the fifth.
- After a restore, auto-renewal is switched off, so a restored copy cannot order behind the original's back.

7.4 Network discovery

Discovery finds certificates that servers present on the network, including ones Alice does not manage: an old certificate on a forgotten test server, a self-signed one on a device, a manually installed purchased one. Alice opens a TLS handshake to the addresses and ports an administrator lists, records the chain and closes the connection. It sends no other bytes.

Safety rules

- Nothing is scanned by default. With the "Allowed scan networks" list empty (the default), no scan is possible.
- Built-in refusals: loopback, link-local and cloud metadata addresses, multicast, reserved and CGNAT ranges, Alice's own addresses, the default gateway and the database. The rule is applied when the socket connects, so DNS rebinding does not help. No proxies, no redirects.
- Limits: number of addresses, rate (20 connections per second by default), concurrency, duration (60 minutes), chain size; at most two scans at a time.
- A scan of a /20 network means thousands of TLS connections within minutes and may trigger intrusion detection. Tell the people who run it first, and start small.

8 Identity, roles and access

8.1 Roles

Role	Can	Cannot
Administrator	Everything: users, settings, audit trail, others' API tokens, deployment with an incomplete chain, adding Key Vaults, downloading private keys, rotation policies, certificate authorities and DNS hooks, auto-renew/auto-deploy, discovery scopes and allowed networks.	—
Operator	Sees the inventory. Tests servers, scans, removes SSH keys, generates and deploys keys, uploads certificates, creates CSRs and deploys. Runs Key Vault checks, ACME test runs and orders, starts and cancels scans. Manages own API tokens.	User management, audit trail, settings, incomplete-chain deploys, private-key download, rotation management, defining authorities or scopes, turning on auto-deploy.
Auditor	Read-only view of the inventory and discovery results. Views, exports and verifies the audit trail. Own read-only API tokens.	Any change.

Every API route maps to exactly one permission, and every permission maps to roles and token scopes. There is no route without a permission, and a test checks every route against every role. The full matrix, `docs/authz-matrix.md`, is generated from the route table.

8.2 Local accounts and MFA

- Passwords: at least 12 characters, checked against a list of 100,000 leaked passwords, and hashed with **Argon2id**.
- Every local account **must** use a TOTP authenticator app; MFA cannot be switched off. Ten one-time recovery codes stand in for a lost phone.
- Sign-in protection: after 5 failed attempts, waits of 1, 2, 4, 8 and 16 seconds; after 10 attempts, a 15-minute block. During a block even the correct password gets the same "wrong user name or password" answer. Every block is audited and e-mailed to the recipients.
- Sessions end after 30 minutes of inactivity and in any case 12 hours after sign-in. Only real input counts as activity; self-refreshing pages do not.
- **Step-up** ("Confirm it's you"): user and settings management, licence upload, private-key download, backups and re-pinning a host key all require a fresh code from the last 5 minutes.
- The last active local administrator can never be disabled or demoted (break-glass account).

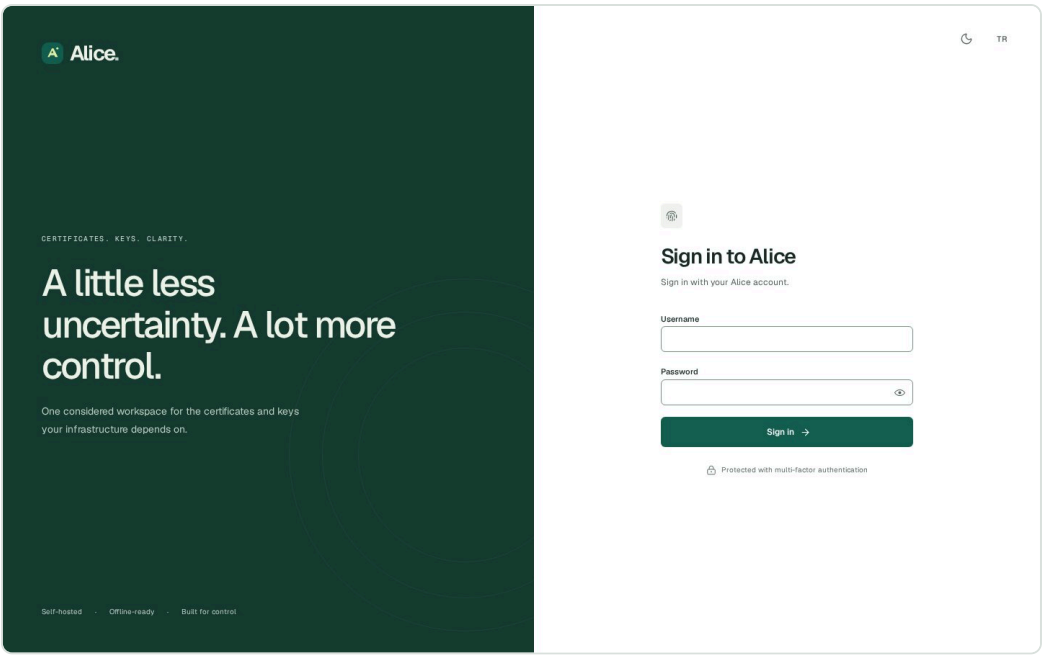


Figure 17. The sign-in page. When SSO or a directory is configured, "Sign in with …" and "Sign in to" options appear here.

8.3 Single sign-on (OpenID Connect)

Microsoft Entra ID, AD FS, Keycloak and other OIDC providers are supported, with group-to-role mapping. MFA is then the identity provider's responsibility. "SSO users can be administrators" is off by default, and the local break-glass administrator always remains. Only RS256/ES256/PS256-signed tokens are accepted and redirects are not followed. The limits are 5 providers and 200 mappings per provider.

8.4 LDAP and Active Directory sign-in

People choose a directory under "Sign in to" and use their directory name and password. Alice finds the person with a read-only service account, verifies the password by binding **as that person** over `ldaps://`, reads their groups, grants the highest mapped role and, by default, also asks for Alice's own TOTP code. The person's identity is the directory's unique ID (`objectGUID` or `entryUUID`), never the name or e-mail.

> **Security note**
>
> Unlike with SSO, the directory password passes through Alice. It is used for one bind and is never stored, logged or audited. TLS is mandatory and verified (no plain `ldap://`, no StartTLS, no referrals). Every refused sign-in gets the same answer after at least 1.5 seconds. Three failures in 30 minutes, per name and per directory account, pause that name for 45 minutes, which keeps Alice below a typical AD lockout threshold. **Tested only against OpenLDAP and Keycloak; a real AD test is pending.**

8.5 API tokens

Tokens are personal, scoped `read` or `operate`, valid for at most 365 days, and stored only as a hash. A token follows its owner's role: if the role changes or the account is disabled, so does the token. SSO and directory users cannot create tokens, and auditors get read-only tokens only. No action that requires step-up can be done with a token.

9 Security architecture and threat model

9.1 What is stored where

Data	Where	Protection
Users, roles, password hashes, TOTP secrets, recovery codes, sessions, API token hashes	Database	TOTP secrets envelope-encrypted; passwords and tokens hashed only.
Managed private keys (TLS, generated SSH), Alice's SSH key, Key Vault credentials, SMTP password, OIDC secrets, directory service password, ACME account keys, DNS-hook secrets	Database	Envelope encryption under the master key; each value bound to its own row.
Inventory and discovery results (public data only)	Database	Database access control.
Audit trail	Database	Hash chain; the application can only insert and read.
Master key	`/opt/alice/keys/master.key`	Mode 0400, owned by the container user, in a 0700 directory; full-disk encryption required.
Database passwords	`/opt/alice/secrets/`	Root only; read as Docker secrets; never in environment variables or logs.
Backups	`/opt/alice/backups/`	Encrypted files, mode 0600.

Logs contain no secrets. Passwords, keys, tokens and the recovery passphrase are never written to a log, audit entry, job parameter or error message. The test suite proves this with planted canary values.

9.2 Cryptography

- **Envelope encryption:** each secret has its own random 256-bit data key (AES-256-GCM), and the data key is encrypted with the 256-bit master key. Hardware key storage (TPM/HSM) is not in version 1.
- **Passwords:** Argon2id.
- **Backups:** X25519 + HKDF-SHA256 + AES-256-GCM in 64 KiB chunks. The backup private key is sealed inside the file with a key derived from the recovery passphrase (Argon2id, 64 MiB, 3 passes), and each file is also bound to the installation's sender key.
- **Transport:** HTTPS (TLS 1.2+), SSH to managed servers, and verified TLS to Azure, mail, syslog and LDAP.
- **Releases and licences:** Ed25519 signatures. The release key is separate from the licence key; the licence key lives on a YubiKey.

9.3 The audit trail

Every sign-in, failure, refused request and change is recorded with actor, address, object and result. Each entry carries the SHA-256 hash of the previous entry and of its own content, so changing or deleting an entry breaks the chain. The application's database role can only insert and read, and triggers refuse changes for every role. Alice checks the chain daily and on demand (`alicectl audit verify`). Forwarding sends each entry to a SIEM as RFC 5424 syslog (TLS by default) with sequence number, hash and previous hash, so gaps are visible. Writing

the head hash somewhere outside Alice from time to time (for example in a ticket) makes later truncation detectable.

9.4 Container hardening and supply chain

The Alice container runs as user 10001 with a read-only root file system, a small non-executable in-memory `/tmp`, all Linux capabilities dropped, `no-new-privileges`, core dumps off, limits of 2 CPU / 1 GiB / 512 processes, and a distroless image with no shell. PostgreSQL 16 is pinned by digest and runs as user 70 without a published port. Schema changes are made by a separate owner role in a one-off container, and no role is a superuser.

The release bundle lists every file's SHA-256 in an Ed25519-signed `SHA256SUMS`, ships CycloneDX SBOMs, and pins Go modules, npm packages, base images and build tools by version or digest. The release gates run govulncheck, osv-scanner, npm audit, Trivy, gitleaks, gosec, ShellCheck and actionlint, and their results go into each release's `SECURITY-REPORT.md`.

9.5 Threat model summary

Scenario	Main controls	Remaining exposure
Alice itself is compromised	MFA, roles, step-up, the narrow helper on servers, audit forwarded off-box	Alice reaches every managed server; a full takeover reaches all of them, within the helper's command set.
Database or backup stolen	Envelope encryption; backups sealed with the recovery passphrase	Database and master key together, or backup and passphrase together, reveal the secrets.
Malicious operator	Cannot download private keys, read the audit trail or define authorities and scopes; every action is audited	Can deploy certificates for approved names, order certificates, and add or remove keys.
SSRF (ACME, hooks, discovery)	Only administrators set addresses; https only; address rule; no proxy or redirects; 1 MiB response cap	An administrator can point Alice at any https address it can reach.
Man in the middle	TLS everywhere; SSH host-key pinning	First contact with a new server depends on the administrator comparing the fingerprint.
Tampered update	Signed bundles verified with installed keys (never with keys from the new bundle); automatic backup and fallback	The first install depends on the operator comparing the published fingerprint.

9.6 Assurance work and compliance

The project has had several independent reviews, kept under `docs/security/reviews`: network discovery, LDAP sign-in, an outside multi-agent review, an independent audit and a production-readiness review on 16 October 2026. Their findings are traced to fixes in `docs/security/traceability.md`. The security guide maps access control, strong authentication, session management, logging and monitoring, log integrity, encryption at rest and in transit, key management, backup and continuity, change management, vulnerability management, data location and privileged access to Alice features. It also lists the evidence an auditor can collect for each (authorisation matrix, audit exports, SBOM, update logs, drill log). This mapping is guidance oriented to KVKK and BDDK, **not** legal advice or a certification.

Vulnerability handling: acknowledgement within 3 business days, triage within 7 days, coordinated disclosure after 90 days by default. Target fix times: Critical 14 days, High 30 days, Medium in the next minor release.

10 Backup, restore and upgrade

10.1 What a backup contains

A backup is one encrypted file. It holds the whole database (users and encrypted TOTP secrets, tokens, servers, certificates and their encrypted keys, SSH keys, Key Vault credentials, ACME accounts, rotations, jobs, settings, licence and Installation ID, and the full audit trail), the master key, the HTTPS certificate and key, and the licence clock record. The database is read in one consistent snapshot while Alice runs, and nothing is written to disk unencrypted.

Type	Created by	Deleted automatically?
auto (daily)	Daily schedule (default 02:30, server time zone)	Yes, beyond the number kept (7–60, default 14)
manual	"Back up now" or `alicectl backup`	No
pre-restore	A restore, of the data it replaces	No
pre-upgrade-<version>	An upgrade, before it changes anything	No

Taking a backup needs no passphrase; opening one needs **only** the passphrase, even on a new server. If there has been no successful backup for 48 hours, every page shows a red banner and an e-mail is sent.

> **The recovery passphrase**
>
> It cannot be changed in this version and is stored nowhere. If it is lost, no backup can be opened. If it leaks, someone who has it and a backup file can forge a backup that opens with it (known issue KI-14). Keep it as secret as the master key, and keep backup copies write-protected and access-controlled.

10.2 Off-site copies and drills

Follow the **3-2-1 rule**: 3 copies, on 2 kinds of media, 1 off-site, with the passphrase stored apart from the backups. The guide gives recipes for rsync, SMB, S3 and rclone that copy only `.alicebak` and `.sha256` files and never overwrite an existing copy. Every 6 months, run a **disaster-recovery drill**: restore the newest off-site copy on a spare VM that cannot reach production, check sign-in, counts, `alicectl audit verify` and `alicectl selfcheck` (seven OK lines), record RTO/RPO, and destroy the VM. The design target is a 30-minute recovery on a prepared server; no drill result has been recorded yet for this version.

10.3 Restore

```
sudo /opt/alice/alicectl backup verify /opt/alice/backups/<file>          # quick, no passphrase
sudo /opt/alice/alicectl backup verify /opt/alice/backups/<file> --deep   # full decrypt, changes
nothing
sudo /opt/alice/alicectl restore /opt/alice/backups/<file>                # replaces all data
```

A restore first opens the whole file while Alice is still running, shows what it contains and asks you to type `RESTORE`. It then stops Alice, loads the backup into a separate database, checks row counts, the audit chain, the master key and the installation record, saves the current data as a pre-restore backup, and only then switches over in one step. If any check fails, the current data stays in use. Afterwards jobs that would change servers wait for an administrator, and ACME auto-renewal is off. When restoring to a **new** server, the licence, Installation ID and Alice's SSH key come with the backup, but the old server must be shut down, otherwise two copies would rotate keys on the same servers.

10.4 Upgrade

```
cd /opt/alice && sudo ./alice-update.sh /root/alice-1.0.1.tar.gz
```

The upgrade script runs checks that change nothing. The signature is checked against the **installed** release keys, never against keys from the new bundle, and the script also checks that the new version is newer, the minimum upgrade-from version, selfcheck and disk space. It then stops jobs (giving them 60 seconds), takes a pre-upgrade backup and verifies it fully with the passphrase, saves a rollback copy of the configuration, loads the images and checks their IDs, migrates the database, starts and runs selfcheck. If anything fails, the installed version is brought back automatically. The script never moves to an older version; going back means restoring the pre-upgrade backup with the old bundle.

11 Licensing and the vendor console

11.1 How the licence works

Alice is licensed per installation, by the number of **managed targets**: Nginx, Apache, HAProxy and Linux servers, and Azure Key Vaults. Certificates, SSH keys, authorities and issued certificates are not counted. Each installation has an **Installation ID** such as `ALICE-7F3K-9Q2M-XD41-B8TC`, which survives backup and restore, so a licence keeps working after a move to new hardware.

When	Who sees what	What works
Evaluation (first 30 days, 5 targets)	Everyone: blue banner; administrators warned 7, 3 and 1 days before the end	Everything
60, 30, 14, 7, 1 days before expiry	Administrators: yellow/orange banner and an e-mail each time	Everything
7-day grace period after expiry	Everyone: red banner; administrators get a daily e-mail	Everything
After grace (lock mode)	"Licence expired. Automatic tasks are paused."	See below

In **lock mode** Alice makes no changes on servers and pauses automatic server-changing work. No data is lost and no certificate is revoked. Sign-in, viewing, licence upload, backups, the audit trail, user management, tokens and settings keep working. Licence files are signed: an edited file is "not a valid Alice licence". A clock moved backwards does not extend a licence, and a clock that jumps forward by more than two days falls back to the last known time for 24 hours and warns administrators.

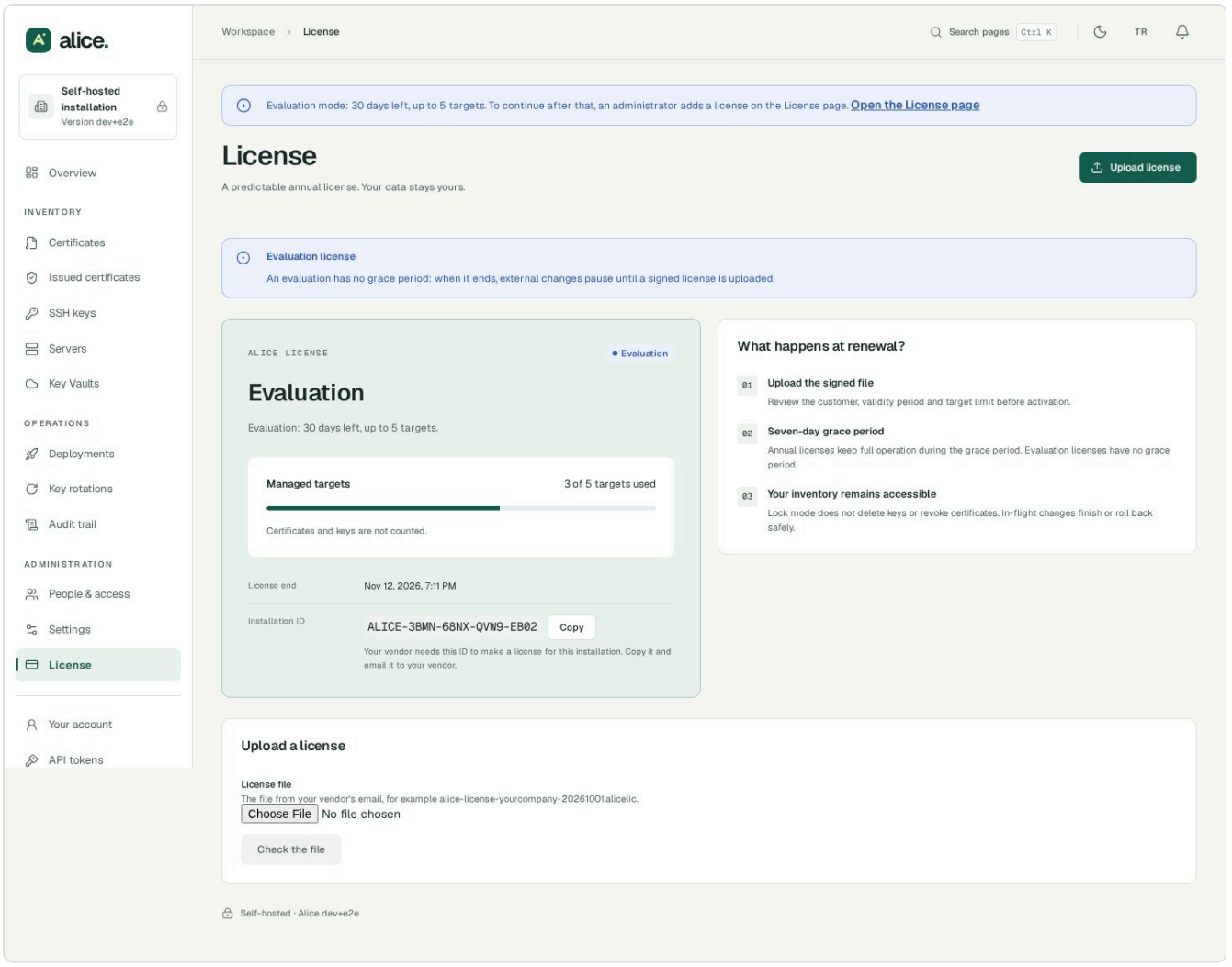


Figure 18. The Licence page: Installation ID, validity, target count and licence upload.

11.2 The vendor console

The vendor console is the **vendor's** internal tool and is never part of a customer build. It keeps customers, licence requests and issued licences in a PostgreSQL database (connections only with `sslmode=verify-full`, one login per person, the group roles `vendor_sales`, `vendor_signer` and `vendor_owner`, row-level rules, and an audit row for every change). It also issues licences from requests. The signing key for production licences (`vk-2026-02`) was created in a ceremony on 18 October 2026 and lives on the owner's **YubiKey** with touch and PIN required. A small sales web app (`vendor-web`, recently redesigned with light and dark themes) lets the sales team open requests, with in-app notifications for upcoming expiries and pending requests.

12 The API and day-to-day operation

12.1 API

Everything is under `https://<address>/api/v1/`, and the web interface uses the same API. Every operation, its parameters, its response and its required permission are described in `api/openapi.yaml` (OpenAPI 3.1, `x-permission`). Times are UTC, RFC 3339.

```
read -rs ALICE_TOKEN && export ALICE_TOKEN
# certificates that expire within 30 days (expired included), paged
curl -fsS -H "Authorization: Bearer $ALICE_TOKEN" "https://alice.example.com/api/v1/certificates?
expiry=30&limit=200"
# export the audit trail (integrity result in a header)
curl -fsS -D headers.txt -o audit.json -H "Authorization: Bearer $ALICE_TOKEN"
"https://alice.example.com/api/v1/audit/export?format=json"
```

- **Errors** are JSON with a stable `code` (for example `ALC-SYS-0001`), `reason`, `message`, `request_id` and `retryable`.
- **Paging** uses `{"items": […], "next_cursor": "…"}` with a limit of 1–200 (default 50) and opaque cursors.
- **CSRF:** changing requests from a browser must be same-origin and carry `X-CSRF-Token`. Bearer-token requests are exempt.
- **Limits:** unknown token or session, 60 requests per minute per address; per-action limits (429 with `Retry-After`); body-size limits (413).

12.2 Server operation

Command (`sudo /opt/alice/alicectl …`)	What it does
`backup`, **`backup list`**, **`backup verify FILE [--deep]`**	Manual backup; list; quick or deep verification.
`restore FILE`	Replaces all data with the backup (see 10.3).
`selfcheck`	Seven checks: database, schema version, master key, audit chain, licence, HTTPS listener, background-job heartbeat.
`audit verify`	Verifies the audit chain and records the result in the audit trail.
`setup-token --reset`	A new one-time setup code, only while no administrator exists.
`support-bundle`	A support bundle of logs and configuration summary, with no secrets.
`alice admin reset-mfa / unlock <user>`	Inside the container: reset the only administrator's MFA or lift a sign-in block (audited with actor `cli`).

Logs are read with `docker compose logs`. They are structured and contain no secrets. Watch the size of the backup directory and the growth of the audit trail, and run `selfcheck` after a reboot. When someone leaves: disable their account (which ends sessions and tokens), remove their personal SSH keys from servers, and rotate keys if needed.

13 Engineering practice: stack, testing and CI

13.1 Technology stack

Back end	Go 1.27: one static binary, no CGO, reproducible builds with `-trimpath`. PostgreSQL 16 pinned by digest. A distroless/static base image with no shell.
Front end	React 18, TypeScript 6, Vite 8, TanStack Query, react-router, i18next (EN/TR catalogues). The built UI is embedded in the Go binary.
Delivery	Docker Compose and a signed release bundle (`install.sh`, `alice-update.sh`, `alicectl`). Images are loaded from the bundle, not pulled from a registry.
Security tools	govulncheck, osv-scanner, npm audit, Trivy, gitleaks, gosec (golangci-lint), ShellCheck, actionlint, OWASP ZAP; CycloneDX SBOM.

13.2 Repository layout

Directory	Contents
`cmd/alice`	The main server binary (serve, migrate, setup-token, audit verify, admin, licence commands). Test-only endpoints exist only in builds with test build tags.
`cmd/alice-helper`	The static helper installed on managed servers (amd64/arm64).
`cmd/licensectl`, **`vendor-console`**, **`vendor-web`**	Vendor-side tools; not part of the customer bundle.
`internal/`	Domain packages: acme, audit, auth, backup, certs, discovery, inventory, jobs, license, providers (linuxssh, nginx, apache, haproxy, azurekv), rbac, secrets, sshkeys, webui… `archtest` enforces architecture rules.
`web/`	The React application, with Playwright scenarios under `web/e2e/`.
`api/openapi.yaml`, **`migrations/`**, **`deploy/`**, **`docs/`**	API contract; numbered SQL migrations (now 00018) frozen by a test; Dockerfile, compose and release scripts; guides, security reviews, design specs and plans.

13.3 Test layers

Layer	What it proves
Go unit tests	Run with the race detector. Architecture tests check build-tag leaks and secret-handling rules.
Integration	With real PostgreSQL in Docker, a fake TLS fleet for discovery, and OpenLDAP for directory sign-in.
Real-server matrices	Real OpenSSH, Nginx, Apache and HAProxy (2.4/2.6/2.8) on Ubuntu 22.04, Debian 12 and Rocky 9 containers: discovery, deployment, rollback and recovery; Nginx reload with systemd as PID 1.
Web unit tests	Vitest, with a test for every page and coverage thresholds.

Layer	What it proves
End-to-end	Playwright in Chromium (Firefox and WebKit nightly and at release), EN and TR. Full journeys against fake ACME, Azure, IdP, SMTP, LDAP and SSH targets, plus accessibility (axe) checks.
Release harness	Install, backup/restore drill, upgrade and fallback on three distributions (~30 min).
Fuzz and mutation	Fuzzing of SSH, OIDC and LDAP parsing; mutation testing of the backup format and licence packages.
Gates	Lint, i18n key parity, authorisation-matrix drift, per-package coverage floors, vulnerability, secret, file-system and image scans, hardening and release-symbol checks.

`make ci` runs the whole GitHub Actions pipeline locally. The release image contains no test symbols, test licence keys or `/test` routes. `image-check` proves this, and the end-to-end image serves as the negative control.

13.4 Way of working

Every feature starts with a design spec (`docs/superpowers/specs`) and a phased plan (`docs/superpowers/plans`), is written test-first, and ends with a review. Decisions taken during implementation are recorded as **rulings** (`docs/superpowers/rulings`). Independent security reviews and their traceability to fixes are part of the repository. The release checklist records the steps only the owner can perform, such as signing ceremonies.

14 Project status, limitations and open items

14.1 Delivered

Work package	Status
Core phases 0–11 (inventory, deployment, SSH keys, Key Vault, ACME, backups, upgrades, licensing, audit)	**Done** merged and pushed
Network discovery	**Done** tested only against emulated servers and loopback
LDAP / Active Directory sign-in	**Done** tested with OpenLDAP and Keycloak; real AD pending
Production-readiness review (16 Oct 2026)	**Closed** fix-before-release items fixed; a few items deferred to 1.0.x or owner decision
Apache and HAProxy providers	**Discovery only** deployment not yet built
Vendor console and licence signing	**Done** production licence key on YubiKey (18 Oct 2026); Linux hardware test passed
CI	**Green** all 8 CI jobs on the latest commit, full end-to-end included

14.2 Known limitations of version 1 (by design)

- The recovery passphrase and the master key cannot be changed, and there is no TPM/HSM support.
- **Blast radius:** Alice can reach every managed server. The narrow helper limits what it can do there, but a full compromise of Alice affects all managed servers.
- The audit chain proves changes in the middle of the trail. Someone in full control of the server could cut off the newest entries; forwarding to a SIEM and recording the head hash outside Alice make this visible.
- ACME has been tested only against an emulated authority, so validate with the real CA's staging service. Network discovery has not been tested on real networks.
- Directory sign-in has been tested only with OpenLDAP and Keycloak. A locked name unlocks only when Alice restarts.
- Apache and HAProxy: discovery only. HAProxy `conf.d` directories are not read.
- Going back to an older version is possible only by restoring a backup, and this path has not been tested yet.
- Alice is a single process with no high-availability clustering in v1.

14.3 Waiting for the project owner

Item	Why only the owner can do it
Directory sign-in against a real Active Directory or Samba AD	The AD preset, nested-group filter and locked/disabled-account answers follow AD documentation; a real directory is needed.
Three LDAP product decisions and the directory lockout policy	Admin "unlock" for locked names; ending sessions when a directory is switched off; AD group name default (`cn` or DN).
Offline release-key ceremony (`rk-2026-01`) and the first signed release	The release key must be created and kept offline by the owner only.

Item	Why only the owner can do it
YubiKey tests on Windows and macOS; spare and IT-manager YubiKeys	Hardware needed.
Install on Rocky 9 with SELinux enforcing, image-ID check on a fresh Docker, external penetration test	Owner steps on the release checklist; unverified until recorded.
Root-only helper test suite; review of a real customer HAProxy configuration	Needs root on a test host and real customer material.
First disaster-recovery drill record	The drill log is held by the owner.
Development Docker DNS setting	Public DNS was added to `/etc/docker/daemon.json` because office resolvers do not answer from containers; a permanent fix is the owner's call.

14.4 Risks a manager should track

Risk	Impact	Mitigation
Real-world AD behaviour differs from the documentation	Sign-in problems or unexpected lockouts at AD customers	AD test before the first AD customer; keep local break-glass admin.
Single owner holds keys and ceremonies	Release and licence issuance depend on one person	Spare and IT-manager YubiKeys; written runbook; paper audit-head log.
Customer loses the recovery passphrase	Backups cannot be opened	Wizard warnings; documented storage advice; DR drills.
Expectation of Apache/HAProxy deployment	Sales promises outrun the product	The UI shows the features disabled; communicate "discovery only".
Discovery scans trigger intrusion detection	Alarms or blocked scans at customer sites	Empty allow-list by default; documented warning; start small.

A Glossary

Term	Meaning
ACME	A protocol for getting certificates automatically from a CA (RFC 8555); Let's Encrypt uses it.
alice-helper	The small root-owned program on each managed server that does privileged file work through a fixed command set.
Audit trail	The record of every action. Each entry is linked to the previous one by a hash, so tampering is visible.
Certificate / chain	A signed file that ties a name to a public key. The chain is the intermediate CA certificates that link it to a trusted root.
CA	Certificate Authority: an organisation (or internal system) that signs certificates.
CSR	Certificate signing request: what you send a CA to get a certificate. The private key stays with whoever made it.
Envelope encryption	Each secret is encrypted with its own key, and that key is encrypted with the master key.
Fence	An instruction to the helper to refuse a deployment permanently, so a delayed copy can never run.
Held version	A Key Vault or ACME certificate version that appeared during a licence lock and waits for an administrator to release it.
Installation ID	`ALICE-XXXX-XXXX-XXXX-XXXX`: the identity a licence is bound to; preserved by backups.
Lock mode	The state after a licence and its grace period expire: server-changing work stops and the data is kept.
Master key	The 256-bit key that unlocks every secret in the database (`/opt/alice/keys/master.key`).
MFA / TOTP	A second sign-in factor; TOTP is the 6-digit code from a phone app that changes every 30 seconds.
Overlap	The days during a rotation when both old and new SSH keys work.
Provider / capability	A server type (Nginx, Apache, HAProxy, Linux, Azure) and the features it supports.
Recovery passphrase	The passphrase that opens backups; known only to administrators and stored nowhere.
Scope	In discovery, the administrator-defined addresses, ports and schedule to scan.
SSRF	Server-side request forgery: tricking a server into connecting to places it should not, such as internal or metadata addresses.
Step-up	"Confirm it's you": a fresh verification within the last 5 minutes for sensitive actions.
Target	The unit the licence counts: a Linux, Nginx, Apache or HAProxy server, or an Azure Key Vault.
Trust on first use	Accepting a server's SSH fingerprint at first contact (after an administrator compares it) and refusing any later change.

B. Network ports

Direction	Port	Purpose
Inbound	TCP 443 (`--port`)	Web interface and API (the container listens on 8443).
Internal	TCP 5432 / 8081	Database (Docker internal network only) / health endpoint (127.0.0.1).
Outbound	TCP 22	Managed Linux, Nginx, Apache and HAProxy servers.
Outbound	TCP 443	Azure (`login.microsoftonline.com` , `*.vault.azure.net`), identity provider, ACME directory and DNS hook; no proxy, no redirects.
Outbound	TCP 80	Pre-check of an HTTP-01 token before the CA checks it (only for certificates that use it).
Outbound	Scope ports	Network discovery, only within administrator-defined scopes and allowed networks.
Outbound	TCP 636	LDAP directory / domain controllers (`ldaps://` only).
Outbound	25/465/587, 6514	Mail server; audit-trail forwarding.

C. Error code families

Every error carries a stable code `ALC-<FAMILY>-<NUMBER>` . The full list, with cause and fix for each code, is in `docs/troubleshooting.md` (over 3,400 lines). When asking for help, give both the code and the `request_id` .

Family	Area	Examples
`ALC-SYS`	System and requests	0001 not found · 0005 too many requests · 0007 request too large · 0008 changed while you were editing
`ALC-AUTH`	Authentication	0001 session ended · 0002 no permission · 0003 confirmation needed · 0004 CSRF · 0005 wrong user name or password
`ALC-LIC`	Licence	0001 not available while the licence is expired · 0003 for another installation · 0008 target limit · 0009 licence could not be checked
`ALC-TGT` , **`ALC-SSH`**	Servers, SSH	TGT-0004 server identity changed · SSH-0001 unreachable · SSH-0002 key refused · SSH-0005 helper too old
`ALC-KEY`	SSH keys	0001 Alice's key is protected · 0002 root's last key · 0010 new key log-in not accepted
`ALC-CRT` , **`ALC-DEP`**	Certificates, deployments	Upload refusals, chain problems; DEP-0003 verification failed
`ALC-APC` , **`ALC-HAP`**	Apache, HAProxy	0001 software not found · 0002 configuration problem · 0003 server not prepared · 0004 helper too old
`ALC-AKV` , **`ALC-ACM`** , **`ALC-DSC`**	Key Vault, ACME, discovery	AKV-0002 credentials expired · ACM-0005 rate-limited by the CA · DSC-0004 already scanning
`ALC-SSO` , **`ALC-LDAP`**	SSO, directories	SSO-0004 Alice address not set · LDAP-0001…0008 connection, TLS, filter and lockout states
`ALC-AUD` , **`ALC-BAK`** , **`ALC-TLS`**	Audit, backup, HTTPS	AUD-0003 syslog receiver unreachable · BAK-0004 disk full · TLS-0001 key does not match

This document was compiled from the English guides in the repository's `docs/` directory (install-guide, first-run, admin-guide, operator-guide, backup-restore, upgrade, licensing, security-overview, api, vendor-console, troubleshooting), the CHANGELOG and the source code as of 19 October 2026. Where they differ, the guides and the code are authoritative.